



Weekly IT Security Brief (Official-source-first) | 2026-05-03 06:03

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 4 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-31431(2026-05-15), CVE-2026-41940(2026-05-03), CVE-2024-1708(2026-05-12). Prioritize internet-facing and privileged systems first.
- Threat trend #1: CVE-2026-31431: Copy Fail vulnerability enables Linux root privilege escalation across cloud environments. A high-severity Linux vulnerability, "Copy Fail" (CVE-2026-31431), enables root privilege escalation across cloud environments and Kube...
- Threat trend #2: Microsoft Agent 365, now generally available, expands capabilities and integrations. Microsoft Agent 365, now generally available, expands capabilities and integrations
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-31431

CVE Title	CVE-2026-31431 linux/linux_kernel Unknown Type
CVE Description	In the Linux kernel, the following vulnerability has been resolved:
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	linux/linux_kernel
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-15
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-31431

CVE-2026-41940

CVE Title	CVE-2026-41940 cpanel/cpanel Auth Bypass
CVE Description	cPanel and WHM versions after 11.40 contain an authentication bypass vulnerability in the login flow that allows unauthenticated remote attackers to gain unauthorized access to the control panel.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	cpanel/cpanel, cpanel/whm, cpanel/wp_squared
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-41940

CVE-2024-1708

CVE Title	CVE-2024-1708 connectwise/screenconnect Unknown Type
CVE Description	ConnectWise ScreenConnect 23.9.7 and prior are affected by path-traversal vulnerability, which may allow an attacker
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	connectwise/screenconnect
Risk Score	8.4 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-12
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2024-1708

CVE-2026-32202

CVE Title	CVE-2026-32202 microsoft/windows_10_1607 Unknown Type
CVE Description	Protection mechanism failure in Windows Shell allows an unauthorized attacker to perform spoofing over a network.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/windows_10_1607, microsoft/windows_10_1809, microsoft/windows_10_21h2, microsoft/windows_10_22h2, microsoft/windows_11_23h2
Risk Score	4.3 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-12
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-32202

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-7001

CVE Title CVE-2026-7001 | 待核實 | XSS

CVE Description A vulnerability was found in Datacom DM4100 1.3.6.1.4.1.3709. This affects an unknown part of the component Ethernet Configuration Page. Performing a manipulation of the argument Name results in cross site scripting. It is possible to initiate the attack remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 2.4 (LOW)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-7001>

CVE-2026-7002

CVE Title CVE-2026-7002 | 待核實 | SQL Injection

CVE Description A vulnerability was determined in KLiK SocialMediaWebsite up to 1.0.1. This vulnerability affects unknown code of the file /includes/get_message_ajax.php of the component Private Message Handler. Executing a manipulation of the argument c_id can lead to sql injection. It is possible to launch the attack remotely.

Affected Products 待核實

Risk Score 7.3 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-7002>

CVE-2026-7011

CVE Title	CVE-2026-7011 待核實 XSS
CVE Description	A weakness has been identified in MaxSite CMS up to 109.3. Affected by this vulnerability is an unknown functionality of the file /admin/plugin_antispam of the component Antispam Plugin. Executing a manipulation of the argument f_logging_file can lead to cross site scripting. It is possible to launch the attack remotely. The exploit has been made available to the public and could be used for attacks. Upgrading to ve...
Affected Products	待核實
Risk Score	2.4 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7011

CVE-2026-7012

CVE Title	CVE-2026-7012 待核實 XSS
CVE Description	A vulnerability was detected in MaxSite CMS up to 109.3. This affects an unknown part of the component Redirect Plugin. The manipulation of the argument f_all/f_all404 results in cross site scripting. The attack can be launched remotely. The exploit is now public and may be used. Upgrading to version 109.4 is able to mitigate this issue. The patch is identified as 8a3946bd0a54bfb72a4d57179fcd253f2c550cd7. You should...
Affected Products	待核實
Risk Score	2.4 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7012

CVE-2026-42254

CVE Title	CVE-2026-42254 待核實 Unknown Type
CVE Description	Hickory DNS hickory-recursor 0.1 through 0.25.2 allows cross-zone poisoning because cached data is not directly associated with a query that triggered a response.
Affected Products	待核實
Risk Score	4.0 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-42254

CVE-2026-7013

CVE Title	CVE-2026-7013 待核實 XSS
CVE Description	A security vulnerability has been detected in MaxSite CMS up to 109.3. Affected by this issue is some unknown functionality of the component mail_send Plugin. The manipulation of the argument f_subject/f_files/f_from leads to cross site scripting. The attack can be initiated remotely. The exploit has been disclosed publicly and may be used. Upgrading to version 109.4 can resolve this issue. The identifier of the pat...
Affected Products	待核實
Risk Score	2.4 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7013



Report B: Threat Intelligence News (last 7 days)

Headline: CVE-2026-31431: Copy Fail vulnerability enables Linux root privilege escalation across cloud environments	
Source	Microsoft Security Blog
Published	Sat, 02 May 2026 03:06:08 +0000
Key Takeaway	A high-severity Linux vulnerability, "Copy Fail" (CVE-2026-31431), enables root privilege escalation across cloud environments and Kubernetes workloads. With a working exploit already in the wild, organizations should act quickly to detect, mitigate, and reduce risk. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-31431
Link	https://www.microsoft.com/en-us/security/blog/2026/05/01/cve-2026-31431-copy-fail-vulnerability-enables-linux-root-privilege-escalation/

Headline: Microsoft Agent 365, now generally available, expands capabilities and integrations

Source	Microsoft Security Blog
Published	Fri, 01 May 2026 15:00:00 +0000
Key Takeaway	Microsoft Agent 365, now generally available, expands capabilities and integrations
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/05/01/microsoft-agent-365-now-generally-available-expands-capabilities-and-integrations/

Headline: CISA, US and International Partners Release Guide to Secure Adoption of Agentic AI

Source	CISA News
Published	Fri, 01 May 26 12:00:00 +0000
Key Takeaway	CISA, US and International Partners Release Guide to Secure Adoption of Agentic AI
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-us-and-international-partners-release-guide-secure-adoption-agentic-ai

Headline: CISA and U.S. Government Partners Unveil Guide to Accelerate Zero Trust Adoption in Operational Technology

Source	CISA News
Published	Wed, 29 Apr 26 12:00:00 +0000
Key Takeaway	CISA and U.S. Government Partners Unveil Guide to Accelerate Zero Trust Adoption in Operational Technology
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-and-us-government-partners-unveil-guide-accelerate-zero-trust-adoption-operational-technology

Headline: Snow Flurries: How UNC6692 Employed Social Engineering to Deploy a Custom Malware Suite

Source	Mandiant Blog
Published	Thu, 23 Apr 2026 14:00:00 +0000
Key Takeaway	Following this, the attacker sent a phishing message via Microsoft Teams, posing as helpdesk personnel offering assistance with the email volume. Finally, EDR telemetry logged the threat actor performing screen captures on the Domain Controllers, specifically targeting in-focus instances of Microsof Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	T1003.001,T1003.002,T1003.003
MITRE ATT&CK	T1003.001, T1003.002, T1003.003, T1005, T1007, T1012, T1016, T1018, T1020, T1021.001, T1021.002, T1027, T1027.010, T1027.015, T1033, T1036.005, T1046, T1053, T1053.005, T1055, T1057, T1059, T1059.001, T1059.003, T1059.006, T1059.007, T1059.010, T1068, T1070.004, T1071.001, T1074, T1082, T1083, T1087.001, T1090, T1105, T1110.001, T1110.003, T1112, T1113, T1134, T1134.001, T1140, T1176.001, T1202, T1204.001, T1204.002, T1489, T1518, T1543, T1543.003, T1547.001, T1547.009, T1552.001, T1559, T1560, T1560.001, T1562.001, T1564.001, T1566.002, T1567, T1567.002, T1569.002, T1572, T1608.002, T1608.005, T1622
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/unc6692-social-engineering-custom-malware/

Headline: Defending Your Enterprise When AI Models Can Find Vulnerabilities Faster Than Ever

Source	Mandiant Blog
Published	Thu, 16 Apr 2026 14:00:00 +0000
Key Takeaway	Introduction Advances in AI model-powered exploitation have demonstrated that general-purpose AI models can excel at vulnerability discovery, even without being purpose-built for the task. Eventually, capabilities such as these will be integrated directly into the development cycle, and code will be Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/global
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/defending-enterprise-ai-vulnerabilities/

Headline: Great responsibility, without great power

Source	Cisco Talos Blog
Published	Thu, 30 Apr 2026 18:00:07 GMT
Key Takeaway	Great responsibility, without great power Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proactive Servi Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/great-responsibility-without-great-power/

Headline: AI-powered honeypots: Turning the tables on malicious AI agents

Source	Cisco Talos Blog
Published	Wed, 29 Apr 2026 10:00:42 GMT
Key Takeaway	This blog shows how generative AI can be used to rapidly deploy adaptive honeypot systems. AI-powered honeypots: Turning the tables on malicious AI agents Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vuln Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/ai-powered-honeypots-turning-the-tables-on-malicious-ai-agents/

Headline: Trellix Confirms Source Code Breach With Unauthorized Repository Access

Source The Hacker News

Published Sat, 02 May 2026 12:11:00 +0530

Key Takeaway Cybersecurity company Trellix has announced that it suffered a breach that enabled unauthorized access to a "portion" of its source code. Trellix did not disclose the Trellix Confirms Source Code Breach With Unauthorized Repository Access --> #1 Trusted Cybersecurity News Platform Followed by 5.70+ Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target ot/待核實

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://thehackernews.com/2026/05/trellix-confirms-source-code-breach.html>

Headline: 30,000 Facebook Accounts Hacked via Google AppSheet Phishing Campaign

Source	The Hacker News
Published	Fri, 01 May 2026 23:39:00 +0530
Key Takeaway	A newly discovered Vietnamese-linked operation has been observed using a Google AppSheet as a "phishing relay" to distribute phishing emails with an aim to compromise Facebook accounts. In all, roughly 30,000 Facebook accounts are 30,000 Facebook Accounts Hacked via Google AppSheet Phishing Campaign Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/l...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/05/30000-facebook-accounts-hacked-via.html

Headline: New Bluekit Phishing Kit Features AI Assistant

Source	SecurityWeek
Published	Sat, 02 May 2026 10:50:00 +0000
Key Takeaway	The post New Bluekit Phishing Kit Features AI Assistant appeared first on SecurityWeek . New Bluekit Phishing Kit Features AI Assistant - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data Bre Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/new-bluekit-phishing-kit-features-ai-assistant/

Headline: In Other News: Scattered Spider Hacker Arrested, SOC Effectiveness Metrics, NSA Tool Vulnerability

Source	SecurityWeek
Published	Fri, 01 May 2026 15:01:27 +0000
Key Takeaway	The post In Other News: Scattered Spider Hacker Arrested, SOC Effectiveness Metrics, NSA Tool Vulnerability appeared first on SecurityWeek . In Other News: Scattered Spider Hacker Arrested, SOC Effectiveness Metrics, NSA Tool Vulnerability - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webc Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Scattered Spider
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-scattered-spider-hacker-arrested-soc-effectiveness-metrics-nsa-tool-vulnerability/

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)